LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	www.bumn.go.id
URL Lengkap	https://www.bumn.go.id/
Tanggal Audit	19 May 2026, 14:36:41 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	Spencer v2.0
Durasi Scan	69.4 detik

SECURITY GRADE: A **SKOR: 91/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **www.bumn.go.id** telah dilakukan pada tanggal **19 May 2026, 14:36:41 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 23 pengecekan keamanan yang dilakukan, sistem mendapat grade **A** dengan skor **91/100**. Ditemukan total **3 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	0	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	2	Risiko sedang, jadwalkan perbaikan
LOW	1	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Cookie: XSRF-TOKEN	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #2: Cookie: portal_publik_kementerian_bumn_session	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #3: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: elb — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **8** | Failed: **3** | Total: **11**

Check	Severity
Server (Info Leak)	LOW
Cookie: XSRF-TOKEN	MEDIUM
Cookie: portal_publik_kementerian_bumn_session	MEDIUM

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **35** | Failed: **0** | Total: **35**

Module 4 — CMS Detection

Passed: **1** | Failed: **0** | Total: **1**

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **2** | Failed: **0** | Total: **2**

Module 10 — Port Reconnaissance

Passed: **1** | Failed: **0** | Total: **1**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **www.bumn.go.id** tidak memiliki kerentanan kritis, namun masih ada beberapa item yang dapat diperbaiki untuk meningkatkan postur keamanan.

Saran perbaikan:

1. [MEDIUM] Cookie: XSRF-TOKEN
Set flag Secure dan HttpOnly pada semua cookie sensitif

2. [MEDIUM] Cookie: portal_publik_kementerian_bumn_session
Set flag Secure dan HttpOnly pada semua cookie sensitif

3. [LOW] Server (Info Leak)
Sembunyikan atau hapus header Server dari response

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 19 May 2026